

Test Report — Mykola's widget no longer replays another identity's conversation

PR: kuantorflow#171 (+ kuantorflow_automation#32, #33) · Issue: kuantorflow#170 · Date: 2026-08-02

Summary

Mykola greeted a signed-out visitor by name and showed the previous conversation, next to a *Sign in with Google* link. Nothing leaked from the server — the widget replayed its own `localStorage` transcript, which carried no record of whose it was. Stored state is now stamped with an opaque per-identity token and restored only on a match. The first cut of the fix did not cover the case that reported it; that was found in review and fixed in a second commit.

What changed

- `app._identity_token()`: a salted SHA-256 digest (16 hex chars) of the user id, falling back to the email; None for anonymous visitors. **A digest rather than the id or email**, because it is written to `localStorage`, which is readable by anything on the origin and survives sign-out. Keyed on the id where there is one (#148), so it outlives an email change.
- Exposed to templates as `mykola_identity` through the existing `inject_mykola()` context processor.
- `templates/base.html`: `saveWidgetState()` stamps the stored state; `loadWidgetState()` compares against `MYKOLA_IDENTITY` and **clears** a mismatched thread rather than ignoring it.

Why a check on load, not another clear on sign-out

Reset Auth (#98) already clears these keys, but in the browser, on form submit — so it only covers a sign-out performed in that tab. Plain **Sign out** has no handler at all, and an identity change decided server-side (a 30-day session expiring, another tab, the pre-#148 repair in #169) can never run that JS. Clearing on the way out cannot be made to work; checking on the way in can.

Automated tests

- **Added:** `tests/test_widget_identity.py` — 14 tests. The token is absent for anonymous visitors, a 16-hex digest when signed in, stable per identity, different between users, unchanged across an email change, and still issued when the users row could not be written. It reveals neither the email nor its local part. The page declares it, `saveWidgetState` stamps it, and `loadWidgetState` both compares and clears.
- **Suite result:** `pytest -m "not live"` — **219 passed** (was 205), 1 skipped, 6 deselected. After merging alongside #89: **241 passed**.
- **Negative check:** with the app change reverted, 11 of the 14 fail.

Manual & browser verification

Driven against the running dev server, reading `localStorage` directly.

First round (the initial fix):

- Thread stamped with a **different** identity → discarded on load: storage reset to the anonymous stamp, transcript back to the nameless greeting, the other name absent from the DOM, panel not forced open.
- Thread stamped identity: `null` (anonymous) → **survived** a reload with messages, chat id and history intact. The check drops mismatches, not everything.
- No console errors.

Second round (after the follow-up commit):

- Thread with **no `identity` key at all** — the shape every pre-existing user actually has — and the previous user's transcript → discarded on load: anonymous greeting restored, chat id cleared, name absent from the DOM, and the state rewritten with an explicit identity: `null`.
- Anonymous stamped thread re-checked → still survives intact, so the stricter check did not over-reach.

Result

Pass, after a real miss worth recording.

The first cut compared `state.identity || null`, which collapses the *absent* key of a legacy thread into the same `null` an anonymous visitor carries — so the stale signed-in transcript was restored for precisely the anonymous visitor a sign-out had just created. The browser check missed it because the planted state carried an explicit identity: `null`, the shape the **new** code writes, rather than the legacy shape every existing user has. Fixed by testing for the key itself; a test now pins the distinction and asserts `state.identity || null` does not return.

Follow-up: `kuntorflow_automation#33` was needed after merging, because `#32` computed its expected token from an email-only session while `#31` gave `user_client` an id — each PR green alone, disagreeing once both were in.